



il Chief Security Officer



Linee Guida per la Classificazione e Protezione delle Informazioni nel Gruppo Ferrovie dello Stato Italiane

Tipologia documento:

Linee Guida

ID: n° 77 _v.01

Ambito di applicazione:

Gruppo

Processo:

Security/ Cyber &
Information Security

Data: 31/10/2024

DISCLAIMER

I principi e le regole di comportamento definiti nel presente documento costituiscono presidi di controllo anche ai fini anticorruzione e di prevenzione dei rischi di compliance e dei rischi-reato ex D. Lgs. 231/2001 dando attuazione a quanto previsto dal Modello di Organizzazione, Gestione e Controllo adottato dalle Società ai sensi del d.lgs. 231/2001 (Modello 231), dal Codice Etico del Gruppo FS Italiane, dalla Policy Anti-Corruption del Gruppo FS Italiane e dal Modello di Gestione Anti-Corruption¹, dal Framework di Data Protection e dal Framework di classificazione e protezione della riservatezza della informazione del Gruppo FS Italiane.

Si raccomanda ai Responsabili delle strutture coinvolte il costante monitoraggio del presente documento al fine di garantirne la corretta applicazione ed il costante adeguamento ai fini della sua efficacia. Chiunque venisse a conoscenza di eventuali violazioni o tentata elusione del presente documento è tenuto ad informare tempestivamente l'Organismo di Vigilanza e/o il Comitato Etico e Segnalazioni di Società, secondo le modalità previste dalla Procedura per la Gestione delle Segnalazioni e dal Modello 231.

PRESIDI DI CONTROLLO

- ☒ D.lgs. 231/2001
- ☒ Anti-Corruption

¹ Ove adottato dalla Società. Il modello è stato pubblicato nella sua prima edizione con la denominazione “Anti-Bribery&Corruption management system” (DdG n. 247 P/AD del 23/02/2018 e corrispondenti documenti societari). Nel rispetto delle proprie peculiarità, Anas SpA ha adottato un proprio modello volontaristico di organizzazione e gestione per la prevenzione della corruzione e trasparenza.



INDICE

SUMMARY	4
IL CICLO DI VITA DELLE INFORMAZIONI.....	6
Creazione	6
Classificazione	7
<i>Informazioni controllate a carattere aziendale</i>	8
Utilizzo	9
Trasmissione.....	10
<i>Ambito di circolazione delle “Informazioni Controllate”</i>	11
Memorizzazione.....	12
Conservazione	13
Cancellazione/Distruzione.....	13
Riclassificazione	13
PROTEZIONE DELLE “INFORMAZIONI CONTROLLATE”	13
INCIDENTI DI SICUREZZA.....	14
PRINCIPALI MISURE DI PROTEZIONE DELLE INFORMAZIONI.....	15
CASI D’USO E LIVELLO DI RISERVATEZZA.....	18
STRUMENTI DIGITALI A SUPPORTO DELLA CLASSIFICAZIONE	20

OGGETTO

Il presente documento definisce uno schema di riferimento e delinea una guida per la classificazione e la protezione delle informazioni contenute in supporti informativi, materiali (cartacei, media ecc.) e non (messaggi e-mail, documenti in formato elettronico, ecc.), che abbiano un valore e un significato nell'ambito del Gruppo Ferrovie dello Stato Italiane (di seguito Gruppo), indipendentemente dai soggetti che le hanno generate (interni o esterni), dalla loro forma (analogica o digitale) e dalle tecnologie utilizzate per il trattamento e la conservazione, attraverso l'adozione di misure in grado di assicurare la conformità ai requisiti di legge e di minimizzare l'esposizione a rischi di incidenti di sicurezza con potenziale divulgazione indebita delle informazioni, anche involontaria.

La linea guida si applica a tutti i dipendenti delle Società del Gruppo e a tutte le terze parti² che, in virtù di un rapporto di lavoro o fornitura, ricevano, trattino ed entrino in possesso di informazioni aziendali in formato digitale o analogico. Dal presente documento sono escluse le informazioni coperte dal segreto di Stato per le quali si adottano specifiche procedure di sicurezza nel rispetto della normativa vigente³.

² Per il tramite di apposite clausole contrattuali che disciplinano gli aspetti relativi alla tutela delle informazioni aziendali in conformità con la presente Linea Guida.

³ Cfr. GR_LG_P_Modello di Gestione per la Protezione dei Dati Personali_n.35_v.01

AMBITO DI APPLICAZIONE

- Ferrovie dello Stato Italiane SpA
- Società del Gruppo FS Italiane

ATTO DI DIREZIONE E COORDINAMENTO ☒**MODALITA' DI RECEPIMENTO DI POLO E DI ADOZIONE SOCIETARIA**

Il presente documento è un atto di direzione e coordinamento a valenza di Gruppo⁴.

Il presente documento è un atto di direzione e coordinamento a valenza di Gruppo.

Le Capogruppo di Settore e le altre Società soggette a direzione e coordinamento di FS SpA, adottano, nel rispetto delle proprie prerogative di autonomia e indipendenza, il presente documento (atto di adozione).

Inoltre, le Capogruppo di Settore con il medesimo atto provvedono al recepimento del documento nell'ambito del rispettivo Polo (atto di recepimento di Polo).

Successivamente, le Società del Polo adottano il presente documento (atto di adozione).

In relazione alle peculiarità organizzative del singolo contesto, l'atto di adozione delle Società del Polo, nel caso in cui siano Sub-holding, può avere valenza anche sulle proprie controllate.

Le Società estere adottano i principi disciplinati in coerenza con l'ordinamento giuridico ove la Società ha la sede legale.

Ciascuna Società garantisce la corretta e costante applicazione di quanto definito e ne assicura la massima diffusione al proprio interno ed il relativo controllo attuativo anche presso le proprie controllate, nel rispetto degli obblighi di riservatezza e delle prerogative di autonomia ed indipendenza di ciascuna Società.

- ☒ Applicabilità diretta
- ☐ Applicabilità con caratterizzazione organizzativa
- ☐ Applicabilità con integrazione
- ☐ Applicabilità con definizione di processo

⁴ Per Gruppo FS Italiane si intendono le Società italiane o estere controllate da FS S.p.A. ai sensi dell'art. 2359 comma 1, numeri 1) e 2) del codice civile. Italcertifer S.p.A. non è soggetta a direzione e coordinamento, a ulteriore garanzia della sua indipendenza in relazione all'attività svolta. Gli atti di direzione e coordinamento emanati dalla Holding sono inviati ad Italcertifer quali descrizione degli indirizzi adottati nell'ambito del Gruppo FS, che potranno essere valutati dal management di Italcertifer nell'ambito della propria discrezionalità gestionale.

IL CICLO DI VITA DELLE INFORMAZIONI

Il ciclo di vita delle informazioni può essere schematizzato secondo le fasi riportate nella Figura 1, non tutte necessariamente sempre presenti e talvolta non distinte nettamente tra loro:

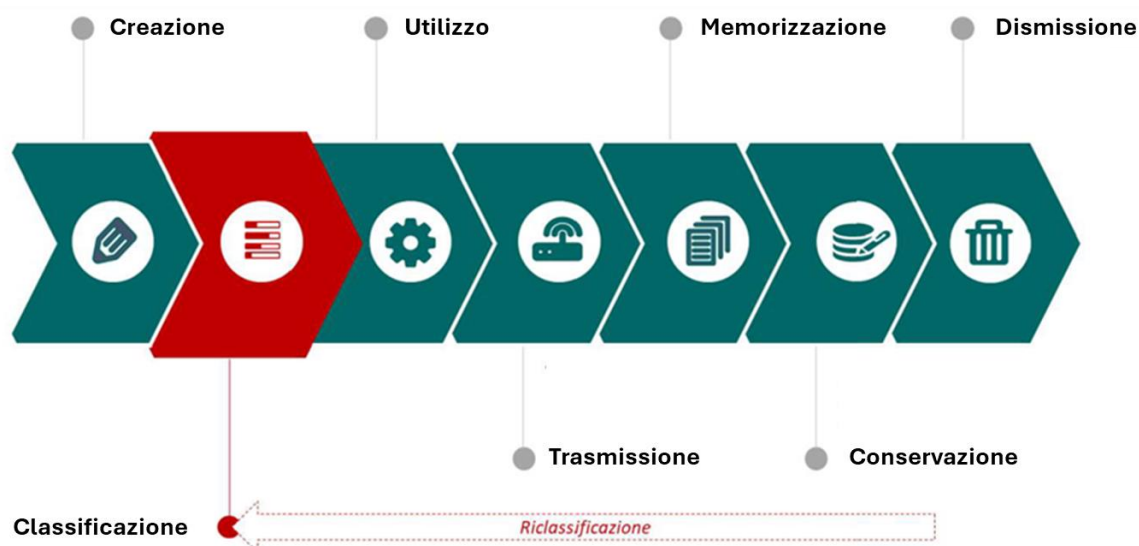


Figura 1 – Ciclo di vita delle informazioni

Creazione

L'informazione può essere generata dall'elaborazione di dati elementari o acquisita da sorgenti interne o esterne⁵. Durante tale fase, devono essere garantite misure di sicurezza tecnico-organizzative sufficienti a salvaguardarne la riservatezza, senza inibire l'operatività degli utenti. Quando la stessa informazione risiede in più supporti, occorre proteggerla adottando contromisure adeguate alle diverse caratteristiche dei singoli supporti, che possono essere:

- **digitali**: qualsiasi forma di informazione generata, elaborata, memorizzata o trasmessa su un sistema informatico aziendale (ad es. *servizi di cloud computing* o *server* esposti su *intranet* o *Internet* che gestiscono *e-mail*, *file*, *record*, *log*, ecc.) o personale (ad es. *PC*, *laptop*, *smartphone*, *tablet*, *USB drive*, ecc.);
- **analogici**: qualsiasi forma di informazione scritta a mano, stampata, elaborata, archiviata o trasmessa su supporto analogico (ad es. registri, appunti, documenti, corrispondenza, fax, nastri audio e video, ecc.) sia in originale sia in copia.

A ciò si aggiunge qualsiasi forma di informazione orale appartenente al patrimonio di conoscenze di ciascun dipendente o terza parte trasmessa verbalmente (ad es. conversazione, discorso, intervista, ecc.).

⁵ Qualora l'informazione venisse acquisita da una fonte esterna al perimetro aziendale o di Gruppo (ad es. da un fornitore esterno), l'informazione seguirebbe il medesimo ciclo di vita di un'informazione prodotta/acquisita internamente.

Classificazione

In questa fase si procede secondo i criteri definiti nei successivi paragrafi ad assegnare una rilevanza a ciascuna informazione sulla base del possibile danno, diretto o indiretto, che potrebbe scaturire dall'utilizzo improprio dell'informazione e dalla conseguente perdita di riservatezza della stessa, dalla massività e particolarità dei dati personali trattati, dalla vulnerabilità degli interessati i cui dati personali sono trattati.

A ciascun livello di classificazione sono associate misure di sicurezza tecnico-organizzative a protezione dell'informazione. L'*Information Owner* deve garantire che la classificazione sia effettuata con le modalità indicate nel presente documento. L'informazione acquisita dall'esterno (ad es. da un fornitore) va classificata secondo i criteri definiti nel presente documento, indipendentemente dall'eventuale pregressa classificazione attribuita al documento da parte del mittente esterno.

L'attribuzione di un livello di classificazione alle informazioni, in funzione della loro sensibilità, è necessaria per adottare le misure adeguate a garantirne la sicurezza in tutto il loro ciclo di vita. Classificare significa, pertanto, attribuire alle informazioni un "valore" a cui corrisponde un determinato ambito di circolazione e livello di protezione. L'apposizione di una etichetta di classificazione permette di tutelarne:

- la **riservatezza**, contrastando l'accesso non autorizzato alle informazioni e la loro diffusione non autorizzata;
- l'**integrità**, contrastando o quantomeno rendendo rilevabili eventuali modifiche non autorizzate, accidentali o intenzionali, delle informazioni; qualora sia certificata l'origine di un'informazione (ad es. con l'indicazione del soggetto che l'ha generata), le azioni di tutela mirano anche a garantire l'autenticità del corrispondente riferimento (ad es. tramite l'utilizzo della firma digitale);
- la **disponibilità**, contrastando eventuali cancellazioni non autorizzate, accidentali o intenzionali, delle informazioni; la valutazione della disponibilità è comunque parte integrante della classificazione e postura di sicurezza di un sistema informativo.

Le misure di sicurezza da adottare nelle diverse fasi del ciclo di vita di un'informazione devono essere calibrate al livello di classificazione attribuito dal gestore dell'informazione. Anche nei rapporti con soggetti esterni contrattualizzati (consulenti, studi legali, ecc.), lo scambio di documenti contenenti informazioni dovrà garantire, nel rispetto di misure di sicurezza coerenti con il Framework di Data Protection⁶, l'applicazione dei criteri di classificazione e protezione delle informazioni contenuti nel presente documento, anche in ragione delle dotazioni tecnologiche in uso al Gruppo.

Per le *informazioni contenenti dati personali* il livello di classificazione è stabilito in base alla tipologia di dati ("Dati Personali" / "Dati Particolari"), categorie di interessati, finalità di trattamento e numerosità dei dati coinvolti (di dati personali o di interessati coinvolti), al fine di garantire l'adozione delle misure di sicurezza adeguate nel rispetto della normativa vigente in materia e del Framework Data Protection di Gruppo. Tali Informazioni potranno essere condivise solo con soggetti autorizzati al trattamento dei Dati Personali.

⁶ GR_LG_P_Modello di Gestione per la Protezione dei Dati Personali_n.35_v.01

CLASSIFICAZIONE	INFORMAZIONI CONTROLLATE A CARATTERE AZIENDALE
PUBBLICO	Informazioni accessibili a tutti (interni ed esterni) senza restrizioni, la cui divulgazione non comporta alcun danno alla società. Ad es., fanno parte della classifica le seguenti tipologie: • informazioni pubblicate sui siti Internet delle Società del Gruppo e sui comunicati stampa; • informazioni contenute nel materiale promozionale utilizzato per scopi commerciali e comunicazioni con clienti o potenziali clienti.
AD USO INTERNO	Informazioni accessibili a tutti i dipendenti del Gruppo, a specifici collaboratori autorizzati del Gruppo e a specifici soggetti istituzionali autorizzati vincolati giuridicamente alla riservatezza e prodotte a sostegno delle attività operative interne, il cui contenuto non riveste carattere di confidenzialità in azienda e la cui divulgazione non autorizzata comporta rischi trascurabili (ad es. nominativo dati di contatto aziendale di dipendenti, note organizzative, circolari, disposizioni organizzative, ecc.).
CONFIDENZIALE	Informazioni accessibili solo a persone interne autorizzate, esterne nominalmente autorizzate con vincolo di riservatezza e a specifici soggetti istituzionali autorizzati, vincolati giuridicamente alla riservatezza, e in grado di provocare perdite di know-how, di rivelare eventuali vulnerabilità di processi aziendali, di fornire anticipazioni su future iniziative commerciali, nonché di svelare progetti di innovazione tecnologica, dati personali di dipendenti, fornitori e terze parti appartenenti alla categoria dei dati comuni e dati di contatto aziendale in numerosità limitata.
STRETTAMENTE CONFIDENZIALE	Informazioni accessibili solo a persone nominalmente autorizzate, interne ed esterne con vincolo di riservatezza, e a specifici soggetti istituzionali autorizzati, vincolati giuridicamente alla riservatezza e relative alle strategie ed al core business aziendale, ai dati previsionali di bilancio non ufficiali, alle trattative per l'acquisizione/cessione di asset significativi, alle retribuzioni, ai segreti industriali (comprese le "Notice of invention"), nonché alle informazioni in grado di rivelare eventuali gravi carenze del sistema di controllo interno (ad es. rapporti di audit) e a quelle contenenti dati personali in numerosità massiva o dati particolari (ad es. dati giudiziari, sanitari, valutazioni di dipendenti, ecc.).

Tabella 1 - Livelli di classificazione in base alla tipologia di informazioni controllate

Informazioni controllate a carattere aziendale

Qualora il contenuto informativo da classificare non sia riferibile ad una o più tipologie di informazioni già codificate in azienda - per le quali il rispettivo livello di classificazione da utilizzare come riferimento è stabilito dall'**Information Owner** - si può ricorrere ad una valutazione semplificata basata sulla

valutazione degli impatti. Per le informazioni di natura aziendale il livello di classificazione è stabilito in base all'impatto determinato sul business dell'azienda, sui beni aziendali o sugli individui da una eventuale violazione di sicurezza che comporti la perdita di *Riservatezza*.

LIVELLI DI IMPATTO	DEFINIZIONE	CLASSIFICAZIONE
BASSO (BI)	L'impatto potenziale è BASSO se la perdita di Riservatezza può avere un effetto negativo limitato o determinare un danno lieve sul business dell'azienda, sui beni aziendali o sugli individui.	AD USO INTERNO
MEDIO (MI)	L'impatto potenziale è MEDIO se la perdita di Riservatezza può avere un effetto negativo serio o determinare un danno rilevante sul business dell'azienda, sui beni aziendali o sugli individui.	CONFIDENZIALE
ALTO (AI)	L'impatto potenziale è ALTO se la perdita di Riservatezza può avere un effetto negativo severo o determinare un danno grave sul business dell'azienda, sui beni aziendali o sugli individui.	STRETTAMENTE CONFIDENZIALE

Tabella 2 - Livelli di Impatto

Utilizzo

In questa fase l'informazione nelle sue diverse forme può essere elaborata, gestita, copiata e condivisa dai soggetti autorizzati, esclusivamente nell'ambito delle attività di loro responsabilità e adottando le misure di sicurezza tecnico-organizzative previste per lo specifico livello di classificazione. Il tema delle misure tecniche diventa fondamentale per gestire l'accesso in sicurezza agli strumenti digitali e l'applicazione di livelli di riservatezza crescenti, che nello specifico vanno dalla combinazione "user ID e password" fino all'autenticazione multifattoriale⁷.

Di seguito i ruoli:

- *Process Owner di Gruppo*: responsabile di primo riporto di Presidente/AD di Holding come previsto nelle disposizioni organizzative⁸. Il Process owner definisce il modello di governance relativamente all'ambito di competenza anche individuando attività da presidiare in modo accentrato;
- *Information Owner* (tipicamente responsabile di struttura macro):

⁷ Conosciuta con l'acronimo di MFA (Multi-Factor Authentication), l'autenticazione multifattoriale è un metodo di autenticazione che richiede a un utente di fornire almeno due fattori di verifica (ad es. password, OTP, lo smartphone come token di sicurezza, risposte a domande segrete, chiavi di sicurezza fisiche, riconoscimento biometrico, ecc.) per l'accesso a un'applicazione o a una risorsa.

⁸ DdG n.313/COA Policy Strumenti di Gestione delle Famiglie Professionali. I Responsabili delle sottostanti strutture di FS SpA sono definiti Referenti funzionali di Gruppo per i rispettivi ambiti di competenza. I Responsabili delle omologhe strutture di Società sono i Referenti di processo societari.

- classifica e protegge l'informazione prodotta;
 - tratta l'informazione, rispettando le misure di sicurezza previste dal livello di classificazione associato alla stessa e laddove questa pervenga da altre funzioni aziendali concorrenti/contributrici (ad es. mail interne o pareri, note e raccomandazioni inoltrate a soggetti esterni all'azienda), deve preventivamente acquisire autorizzazione, da queste, ad un eventuale uso esterno della stessa informazione;
 - identifica gli eventuali destinatari dell'informazione prodotta;
 - istruisce e controlla i gestori dell'informazione detenuta o prodotta dalla sua struttura;
 - stabilisce criteri, temporali o operativi, per l'eventuale riclassificazione dell'informazione;
 - gestisce eventuali violazioni nel processo notificate dal Gestore dell'informazione.
- *Gestore dell'informazione* (soggetto a diretto riporto dell'*Information Owner* che agisce in base ai principi del *least privilege*, *need to know/need to use* e *segregation of duties*):
 - produce e classifica l'informazione (nei casi in cui non vi sia chiarezza sul livello di classificazione, il gestore dell'Informazione è tenuto a rivolgersi all'*Information Owner* di riferimento);
 - protegge l'informazione prodotta;
 - in relazione alle attività assegnate, tratta l'informazione, rispettando le istruzioni ricevute dall'*Information Owner* e le misure di sicurezza previste dal livello di classificazione associato alla stessa;
 - identifica gli eventuali destinatari dell'informazione prodotta, anche sulla base delle istruzioni ricevute dall'*Information Owner* e in linea con i criteri definiti nel presente documento;
 - notifica all'*Information Owner* qualsiasi violazione nella gestione delle informazioni (ad es. divulgazione o utilizzo improprio).
 - *Destinatario dell'informazione*: soggetto (interno o esterno alla struttura organizzativa dell'*Information Owner*) autorizzato dal gestore dell'informazione e/o dall'*Information Owner* ad accedere, trattare ed elaborare l'informazione in base ai principi di *least privilege*, *need to know/need to use* e *segregation of duties*. Il destinatario dell'informazione è tenuto a rispettare le misure di sicurezza a salvaguardia della riservatezza del documento.

Trasmissione

Comprende le attività di invio, distribuzione e diffusione⁹ dell'informazione ai destinatari autorizzati, interni e/o esterni al Gruppo, nel rispetto delle vigenti policy sull'utilizzo corretto e sicuro delle risorse digitali¹⁰. La trasmissione può avvenire mediante canali digitali (e-mail, chat, forum, esposizione su intranet, pubblicazione su Internet, ecc.), analogici (invio di corrispondenza cartacea) o verbali (comunicazione diretta o telefonica). La trasmissione viene declinata nelle forme di circolazione delle

⁹ Si intende, nello specifico, quanto segue:

- **invio**: l'informazione è resa fruibile ad un unico destinatario;
- **distribuzione**: l'informazione è resa fruibile ad un numero limitato di destinatari (ad es. popolazione aziendale)
- **diffusione**: l'informazione è resa fruibile ad un numero non quantificabile di destinatari (ad es. pubblico).

¹⁰ Cfr. GR_PY_Utilizzo corretto e sicuro delle Risorse Digitali_n.65_v.01

informazioni:

- *libera*: interna o esterna all'azienda senza alcuna limitazione;
- *controllata*: interna all'azienda nel rispetto del principio need-to-know, ma estendibile anche all'esterno limitatamente ai soggetti autorizzati (che hanno assolto agli adempimenti previsti a garanzia della riservatezza) e quando necessaria per il raggiungimento di finalità legittime o aziendali;
- *controllata e limitata*: come la precedente ma con l'obbligo dell'indicazione esplicita e formale dell'ambito di circolazione.

A ciò si aggiunge la definizione del livello di Protezione ovvero:

- **nulla**, nessuna misura di protezione;
- **base**, misure minime di protezione atte a ridurre il rischio di circolazione non autorizzata delle informazioni;
- **avanzata**, misure di protezione stringenti atte a evitare i maggiori rischi di danni sostanziali dovuti alla circolazione non autorizzata.

CLASSIFICAZIONE	MODALITÀ DI GESTIONE		
	CIRCOLAZIONE	PROTEZIONE	NOTE
PUBBLICA	libera	nulla	//
AD USO INTERNO	controllata	base	Dipendenti del Gruppo, specifici collaboratori autorizzati del Gruppo e specifici soggetti istituzionali autorizzati.
CONFIDENZIALE	controllata e limitata	avanzata	Lista di circolazione circoscritta.
STRETTAMENTE CONFIDENZIALE	controllata e limitata	avanzata	Lista di circolazione nominativa.

Tabella 3 - Tipologia di circolazione e livelli di protezione

Ambito di circolazione delle “Informazioni Controllate”

L'ambito di circolazione precisa le condizioni e i soggetti abilitati al trattamento dei supporti informativi, limitandone la divulgazione al solo personale che rientra nell'ambito autorizzato di circolazione.

Per il livello di *circolazione controllata* si applicano le seguenti regole:

1. le informazioni non devono essere rese disponibili in nessuna forma – orale, visuale ed elettronica - alle persone non autorizzate;
2. l'accesso alle informazioni deve avvenire nel rispetto del principio “need-to-know” come stabilito

dall'Information Owner o per suo conto;

3. l'utilizzatore delle informazioni deve rispettare e non alterare le restrizioni di accesso e di circolazione;
4. i documenti/supporti possono essere riprodotti solo nel rispetto dell'ambito di circolazione;
5. la circolazione all'esterno dei documenti/supporti aziendali classificati è permessa solo quando strettamente necessario e verso quei soggetti abilitati/autorizzati (che hanno assolto agli adempimenti previsti a garanzia della riservatezza) e quando necessaria per il raggiungimento di finalità legittime o aziendali.

Per l'ambito di circolazione controllata e limitata si applicano, in aggiunta, le seguenti regole:

1. i supporti informativi devono essere in grado di gestire la lista di circolazione con le designazioni di strutture, gruppo, ruoli o nominativi in grado di ricondurre univocamente ai destinatari;
2. le informazioni devono essere accessibili esclusivamente alle persone che rientrano nell'ambito di circolazione costituito dalla lista di circolazione;
3. i contenuti non devono essere né riprodotti né comunicati a soggetti diversi da quelli indicati nell'ambito di circolazione.

Memorizzazione

L'informazione può essere memorizzata su supporti aziendali elettronici ¹¹(ad es.: *laptop, sharepoint*, ecc.), analogici (ad es.: *armadi, cassette*, ecc.) o nel patrimonio informativo di una persona, al fine di assicurarne la conservazione durante le fasi di vita "attiva" della stessa, rendendola facilmente accessibile al personale autorizzato. In ogni caso la memorizzazione deve avvenire nel rispetto del Framework di Data Protection, in particolare delle misure di sicurezza e tempi di conservazione.

Per tutte le informazioni cartacee controllate a carattere aziendale (ad eccezione delle sole informazioni classificate come "Pubbliche"), si raccomandano comportamenti idonei a preservare la riservatezza di tali informazioni, secondo il principio del "clean desk".

PRINCIPALI RACCOMANDAZIONI IN AMBITO "CLEAN DESK"

- Proteggere dall'accesso a soggetti non autorizzati gli spazi/ambienti di lavoro non presidiati o vigilati al cui interno sono presenti informazioni cartacee (ad es. chiudere a chiave la porta della stanza e utilizzare armadi/cassettiere, opportunamente protetti, per riporre la documentazione a fine giornata lavorativa, ecc.), non lasciare incustoditi i documenti (ad es. sulla scrivania).
- Stampare i documenti solo se strettamente necessario ed assicurarsi che copie del documento non restino incustodite (ad es. nelle stampanti di rete condivise).
- Assicurarsi di distruggere i documenti una volta esaurita l'esigenza (manualmente o con appositi distruggi-documenti).
- Non lasciare incustodito il documento di identificazione aziendale (ad es. la Smart Card) e le credenziali di accesso alle risorse digitali aziendali.

¹¹ GR_PY_Utilizzo corretto e sicuro delle Risorse Digitali_n.65_v.01)

Tabella 4 - Principali raccomandazioni in ambito “Clean Desk”

Qualora si entri accidentalmente in possesso di un'informazione Confidenziale o Strettamente confidenziale in formato cartaceo (ad es. la stampa di un documento lasciata incustodita in un locale aziendale condiviso), si è tenuti a consegnare immediatamente il documento al proprietario dell'informazione, ovvero al Gestore dell'informazione o all'Information Owner che ha prodotto il documento stesso.

Conservazione

L'informazione può essere conservata (o archiviata), secondo la normativa e disposizioni aziendali vigenti, su supporti elettronici (ad es.: sistemi di *archiving*, ecc.) o analogici (ad es. archivi centralizzati, ecc.), al fine di assicurarne la conservazione al termine del suo ciclo di vita ma prima della sua dismissione (ad. Es. fascicolo relativo ad una causa legale chiusa). Le modalità e le tempistiche di conservazione dipendono, oltre che dal livello di classificazione, anche dalla tipologia di informazione conservata, per esempio in relazione ad eventuali vincoli normativi (ad es. data retention di dati personali). L'accesso all'informazione è consentito, in funzione dei criteri di classificazione e di autorizzazione assegnati, solo per giustificato motivo, nel caso di dati personali l'accesso è consentito solo ad incaricati al trattamento e per finalità dichiarate agli interessati.

Cancellazione/Distruzione

L'informazione è dismessa quando non è più necessaria per il Gruppo o nei casi previsti dalle norme e dalle disposizioni aziendali vigenti, con particolare riferimento alle linee di indirizzo sul periodo di conservazione dei dati personali. La dismissione dell'informazione può avvenire attraverso diverse modalità, passando dalla cancellazione dell'informazione su supporto digitale fino alla distruzione dei supporti fisici (ad es. supporto cartaceo), secondo le vigenti disposizioni aziendali.

Riclassificazione

Fase trasversale che può riguardare ognuna delle fasi precedenti, ad eccezione della prima fase (Creazione) e dell'ultima fase (Cancellazione/Distruzione). L'*Information Owner*, qualora si verifichi qualsiasi cambiamento nella rilevanza o percezione dell'informazione, richiede/impone ed attua la modifica del livello di classificazione precedentemente attribuito all'informazione. La riclassificazione può rendersi necessaria anche a seguito del contributo del destinatario, il quale, qualora ne abbia diritto, può integrare l'informazione (ad es. arricchendola o, più in generale, apportandovi modifiche sostanziali): in tal caso, il destinatario dell'informazione diventa il gestore della nuova informazione, assumendone la responsabilità.

PROTEZIONE DELLE “INFORMAZIONI CONTROLLATE”

La protezione delle *Informazioni Controllate* si ottiene adottando le misure di protezione di tipo preventivo commisurate al livello di classificazione:

- protezione base, da applicare a tutte le informazioni;
- protezione avanzata, da applicare all'informazione "CONFIDENZIALE" e "STRETTAMENTE CONFIDENZIALE", ad integrazione o modifica delle misure di protezione base.

Nella fase di protezione è necessario:

1. conservare in modo sicuro le informazioni quando queste non sono sotto il diretto controllo delle persone autorizzate ad accedervi assicurando, coerentemente con il livello di classificazione delle informazioni e dei dati personali, corrispondente copertura delle misure di sicurezza tecnico organizzative previste nella libreria Cyber Security e Data Protection;
2. trasmettere in modo sicuro le informazioni a soggetti interni/esterni all'azienda (utilizzatori) utilizzando un servizio di comunicazione che rispetti le adeguate misure di sicurezza corrispondenti al livello di classificazione (secondo la libreria delle misure di sicurezza tecniche ed organizzative di Cyber Security e Data Protection);
3. verificare l'avvenuta cancellazione delle informazioni trasmesse a soggetti terzi al termine del periodo di conservazione contrattualizzato.

INCIDENTI DI SICUREZZA

L'acquisizione, la lettura, la conservazione, la riproduzione, la comunicazione o la diffusione non autorizzata di informazioni aziendali avvenuta in qualsiasi modalità, costituisce un incidente di sicurezza che può avere importanti conseguenze sia per l'azienda, sia per le singole persone fisiche; pertanto, chiunque entri in possesso anche accidentalmente di informazioni controllate, senza averne titolo o in particolare se di tipo "CONFIDENZIALE" o "STRETTAMENTE CONFIDENZIALE", è tenuto tempestivamente e senza ingiustificato ritardo a:

1. informare:
 - il mittente;
 - l'*Information Owner* (ovvero il responsabile di struttura macro di appartenenza);
 - la struttura C-SOC del Cyber Defence Center di FS Technology (se applicabile);
 - la funzione Data Protection societaria per le valutazioni e azioni di competenza.
2. cancellare il contenuto dell'informazione ricevuta per errore (da ogni proprio sistema o archivio) e non divulgarlo, stamparlo, fotografarlo o copiarlo.

Ogni utilizzo non autorizzato o non altrimenti consentito di informazioni aziendali è rigorosamente vietato e, oltre a violare le presenti linee guida, le disposizioni di Gruppo e aziendali previste in materia e la normativa di protezione dei dati personali vigente, può costituire violazione di altre norme di legge, nonché integrare condotta di rilievo ai fini disciplinari e perseguibile penalmente.

PRINCIPALI MISURE DI PROTEZIONE DELLE INFORMAZIONI¹²

		Misure di protezione base	Misure di protezione avanzata ¹³
Generazione / Rielaborazione / Acquisizione		• Inserire <u>sempre</u> il livello di classificazione delle informazioni su tutti i supporti informativi (materiali e non). • Riportare <u>sempre</u> sui documenti in qualsiasi formato, almeno l'entità emittente e l'Information Owner (se non riconducibile all'unità emittente), l'edizione, la numerazione delle pagine, l'eventuale data di declassificazione. • Apporre il "disclaimer aziendale" ai documenti, ai messaggi diretti a destinatari esterni. E per la tutela dell'<u>integrità</u>: • per i documenti informatici in stesura definitiva, destinati alla conservazione o divulgazione e con particolari esigenze di integrità nel tempo, utilizzare un formato che garantisce l'inalterabilità (c.d. <i>documento statico non modificabile</i>¹⁴).	• Riportare la dicitura "Riproduzione vietata" sui documenti/supporti informativi a circolazione interna. Per la tutela dell'<u>integrità</u>: • per i documenti informatici in stesura definitiva utilizzare <u>sempre</u> il formato "<i>documento statico non modificabile</i>"; • apporre la firma digitale ai "documenti statici non modificabili".
	Memorizzazione	• Cifrare con gli strumenti messi a disposizione dall'azienda le informazioni memorizzate sulle dotazioni individuali mobili (ad es. media rimovibili, notebook, tablet, ecc.).	• Cifrare sempre con gli strumenti messi a disposizione dall'azienda le informazioni memorizzate sulle dotazioni individuali sia fisse che mobili.

¹² Se applicabili in base all'architettura tecnologica della società di appartenenza. Ove non applicabili tali misure sono da intendersi come illustrative delle modalità di gestione della protezione delle informazioni.

¹³ Le misure di protezione avanzata sono misure che integrano o modificano le misure di protezione base.

¹⁴ Documento informatico redatto in modo che il contenuto non possa essere alterato durante le fasi di accesso e di conservazione e risulti immutabile nel tempo; a tal fine il documento non deve contenere macroistruzioni o codice eseguibile, tali da attivare funzionalità che possano modificare gli atti, i fatti o i dati nello stesso rappresentati. Un documento emesso nel formato PDF/A (ISO 19005-1:2005), oppure TIFF o altri formati immagine (jpeg, bmp, ecc.) è conforme ai requisiti di "documento statico non modificabile".

	Custodia	• Custodire i supporti informativi materiali in armadi o cassettiere aziendali muniti di serratura. Tali supporti possono essere conservati in stanze o aree ad accesso controllato, dotate di misure di protezione fisica che impediscono l'accesso a persone non autorizzate. • Custodire supporti informativi immateriali solo su sistemi informativi aziendali dotati di misure di protezione adeguate al livello di classificazione (ad es. con funzioni di controllo accessi coerenti con il livello di classificazione e con l'ambito di circolazione). Non è ammessa la custodia su postazioni di lavoro o dotazioni individuali fisse o mobili.	• Custodire i documenti/supporti informativi in armadi di sicurezza. • Mantenere i documenti informatici in forma cifrata.
	Archiviazione	• Archiviare i documenti/supporti informativi in locali tenuti normalmente chiusi (muniti di serratura), separati dalle aree ufficio e comunque in ambienti idonei alla conservazione per lungo tempo di documenti cartacei o media. • Archiviare i documenti in formato digitale utilizzando gli strumenti aziendali in dotazione¹⁵	• Archiviare i documenti/supporti informativi in armadi o apparecchiature di sicurezza, come ad es. armadi blindati, casseforti, ecc. • Evitare l'archiviazione in siti remoti dei documenti/supporti informativi. • Mantenere cifrati i documenti in formato elettronico avendo cura di garantire nel tempo la disponibilità delle "chiavi" di cifratura.
Comunicazione	Posta cartacea	• Racchiudere i documenti/supporti informativi in un involucro non trasparente o un contenitore. • Sigillare o chiudere il contenitore quando non è sotto il controllo diretto di una persona autorizzata ad accedervi.	• Racchiudere in un doppio involucro o contenitore i documenti/supporti informativi, evitando di apporre il livello di classificazione sull'involucro/contenitore esterno. • Apporre il nominativo del destinatario su entrambe le buste. • Utilizzare il servizio di raccomandata A/R per spedizioni tramite il servizio postale.

¹⁵ GR_PY_Utilizzo corretto e sicuro delle Risorse Digitali_n.65_v.01.

	Posta elettronica	• Trasmettere i messaggi e-mail usando il servizio di posta elettronica aziendale (Microsoft Outlook) ed etichettare le e-mail. • Apporre il “disclaimer aziendale” in calce ai messaggi e-mail diretti a destinatari esterni. E per la tutela dell'<u>integrità</u>: • utilizzare un formato di documento statico non modificabile per allegare documenti informatici che hanno particolari esigenze di Integrità.	• Cifrare sempre i messaggi e-mail. • Inviare i messaggi e-mail con l'opzione di richiesta conferma di lettura. E per la tutela dell'<u>integrità</u>: • firmare sempre elettronicamente i messaggi e-mail.
	Fax	• Utilizzare il servizio Fax solo quando si ha la ragionevole certezza che il destinatario abbia realmente accesso al documento. • Apporre il “disclaimer aziendale” in calce ai messaggi fax diretti a destinatari esterni.	• Utilizzare il servizio Fax solo dopo preavviso al destinatario e dopo conferma che lo stesso ha accesso al dispositivo Fax ricevente, attendendo una sua conferma di avvenuta ricezione.
	Voce		• Effettuare comunicazioni vocali solo se si ha la ragionevole certezza che è garantita la Riservatezza.
	Strumenti elettronici di pubblicazione e condivisione	• Verificare sempre, prima di pubblicare o condividere documenti con limitazioni sulla circolazione, che sia garantita la circolazione solo all'interno dell'ambito stabilito; in particolare non pubblicare documenti su sistemi ad accesso pubblico. • Condividere documenti solo per mezzo di strumenti dotati di controlli accessi con almeno un fattore di autenticazione (UserID/Password). E per la tutela dell'<u>integrità</u>: • Utilizzare il formato “documento statico non modificabile” per pubblicare o condividere documenti che hanno particolari esigenze di Integrità.	• Condividere i documenti solo in forma cifrata quando non è presente una misura di controlli degli accessi logici ad almeno due fattori di autenticazione (Strong Authentication) di cui uno con certificato digitale, smart card o token OTP. E per la tutela dell'<u>integrità</u>: • condividere i documenti utilizzando solo il formato “documento statico non modificabile”.

Distruzione	• Tagliare e cestinare i documenti su supporto cartaceo. • Cancellare le informazioni presenti nei sistemi informativi, utilizzando gli strumenti di “cancellazione sicura” resi disponibili dall’azienda. • Cancellare le informazioni presenti nelle postazioni di lavoro fisse e mobili, utilizzando gli strumenti di “cancellazione sicura” resi disponibili dall’azienda prima della loro dismissione o di un loro riutilizzo. • Rendere non riutilizzabili i supporti informativi materiali (Hard Disk compresi) prima della loro dismissione.	• Distruggere sempre i documenti su supporto cartaceo con apposito apparato “distruggi documenti”. • Distruggere sempre fisicamente i supporti informativi materiali (Hard Disk e media rimovibili).
--------------------	---	---

Tabella 5 - Misure di protezione

CASI D’USO E LIVELLO DI RISERVATEZZA¹⁶

Attività	Pubblica	Ad uso interno	Confidenziale	Strettamente confidenziale
Accesso e visualizzazione del documento digitale	Consentita		Consentita a personale autorizzato con MFA ¹⁷	
Modifica e salvataggio del documento digitale				
Stampa del documento digitale				
Risposta al mittente della mail e a tutti i destinatari (reply / reply to all)	Consentita			
Inoltro mail	Consentita	Consentita a personale autorizzato		
Stampa della mail	Consentita			

¹⁶ Se applicabili in base all’architettura tecnologica della società di appartenenza. Ove non applicabili tali indicazioni sono da intendersi come indicative del livello di riservatezza da garantire.

¹⁷ L’attività è consentita al solo personale, interno o esterno al Gruppo, espressamente autorizzato dall’Information Owner o dal Gestore dell’Informazione (ad es. destinatari di una e-mail, collega che partecipa alla redazione di un documento, ecc.) la cui utenza è protetta da sistema di autenticazione multifattoriale, necessario per la trattazione di informazioni strettamente confidenziali.

Attività	Pubblica	Ad uso interno	Confidenziale	Strettamente confidenziale
Fotocopia				Non consentita (con stampanti/fotocopiatrici ci condivise)
Acquisizione dell'informazione tramite fotografia/video	Consentita	Non consentita		
Consultazione dell'informazione in formato digitale in ambienti aziendali condivisi (ad es. open space)	Consentita		Consentita ponendo attenzione che persone non autorizzate non entrino in possesso dell'informazione	
Consultazione dell'informazione in formato digitale in luoghi esterni all’ambiente di lavoro	Consentita		Consentita ponendo attenzione che persone non autorizzate non entrino in possesso dell'informazione ¹⁸	
Consultazione dell'informazione in formato cartaceo in ambienti aziendali condivisi (ad es. open space)	Consentita		Consentita ponendo attenzione che persone non autorizzate non entrino in possesso dell'informazione	Non consentita
Consultazione dell'informazione in formato cartaceo in luoghi esterni all’ambiente di lavoro	Consentita		Consentita ponendo attenzione che persone non autorizzate non entrino in possesso dell'informazione	Non consentita
Trasmissione su canali fuori dal perimetro di controllo aziendale (ad es. Telegram, Whatsapp, Facebook, ecc.)	Consentita	Non consentita		
Conservazione digitale su sistemi esterni trusted dall’Azienda (ad es. OneDrive, Teams, SharePoint, ecc.)	Consentita	Consentita. Sono richiesti al sistema controlli di accesso ed autorizzazione delle utenze, al fine di verificare che solo le persone autorizzate possano accedere all'informazione		
Conservazione digitale su sistemi esterni non trusted	Non consentita			

¹⁸ Con l'ausilio di strumenti atti a preservare la *protezione dei dati personali* sullo schermo dei device (ad es. pellicole "privacy filter").

Attività	Pubblica	Ad uso interno	Confidenziale	Strettamente confidenziale
(ad es. Dropbox, Google Drive, WeTransfer, ecc.)				
Conservazione copie cartacee e supporti di memoria	Consentita	Custodite in armadi o in cassettiere	Custodite in armadi o cassettiere chiuse a chiave all'interno di locali aziendali o in locali protetti con accesso riservato a personale autorizzato dall'Information Owner	
Dismissione delle informazioni in formato digitale	-	Le informazioni devono essere rimosse dai dispositivi informatici individuali e dai supporti di memorizzazione prima che il dispositivo sia inviato a soggetti terzi per l'esecuzione di attività di assistenza, manutenzione o dismissione, usufruendo del supporto delle Funzioni aziendali preposte per l'utilizzo di tecniche di cancellazione sicura (ad es. wiping e degaussing ¹⁹)		
Dismissione delle informazioni in formato cartaceo	-	Laddove possibile devono essere utilizzati gli appositi apparecchi distruggi documenti. In mancanza di tali strumenti l'utente è tenuto a distruggere le copie cartacee dell'informazione, in modo che non sia possibile la ricostruzione del contenuto del documento		

Tabella 6 - Casi d'uso

STRUMENTI DIGITALI A SUPPORTO DELLA CLASSIFICAZIONE

In ottica di dare applicazione al processo di classificazione delle informazioni controllate su supporti digitali è previsto l'utilizzo di specifiche funzionalità degli strumenti di produttività personale in uso. Tra queste, con particolare riferimento alla trattazione di informazioni "CONFIDENZIALE" e "STRETTAMENTE CONFIDENZIALE", va considerato anche il ricorso a strumenti di autenticazione multifattoriale al fine di incrementare il livello di sicurezza delle applicazioni in uso agli utenti.

Firmato
Salvatore Iannicelli

¹⁹ Il wiping è un processo logico di cancellazione dei dati da un supporto di memorizzazione (ad es. un hard disk), che rende i dati irrecuperabili effettuando molteplici operazioni di cancellazione. Ugualmente, il degaussing è un processo impiegato per rimuovere i dati dagli hard disk, eliminando il campo magnetico che registra le informazioni.

- **Categoria di Sicurezza** - Valutazione dell'impatto potenziale della perdita di riservatezza (R), integrità (I) e disponibilità (D) delle informazioni o degli asset informativi, sull'operatività dell'azienda, sulla sicurezza degli asset o degli individui, espressa attraverso una scala definita di valori.
- **Comunicazione** - Qualunque forma attraverso la quale si dà o si può dare conoscenza di informazioni a uno o più soggetti anche mediante la loro messa a disposizione o consultazione.
- **Data breach** - Violazione di sicurezza che comporta - accidentalmente o in modo illecito - la distruzione, la perdita, la modifica, la divulgazione non autorizzata o l'accesso ai dati personali trasmessi, conservati o comunque trattati compromettendo dunque la riservatezza, l'integrità o la disponibilità di dati personali.
- **Dati particolari** - Dati idonei a rivelare l'origine razziale o etnica, le opinioni politiche, le convinzioni religiose o filosofiche o l'appartenenza sindacale; dati genetici e/o biometrici in grado di identificare in modo univoco una persona fisica; dati relativi alla salute o alla vita sessuale o all'orientamento sessuale della persona; dati giudiziari relativi alle condanne penali o ai reati.
- **Dati personali** - Qualsiasi informazione riguardante una persona fisica (interessato) identificata o identificabile.
- **Disponibilità** - È il grado in cui le informazioni sono disponibili all'utente o al sistema informativo nel momento in cui queste vengono richieste.
- **Documento analogico** - Rappresentazione non informatica di atti, fatti o dati giuridicamente rilevanti.
- **Documento informatico** - Rappresentazione informatica di atti, fatti o dati giuridicamente rilevanti²⁰.
- **Documento informatico firmato** - Documento informatico sottoscritto con firma elettronica qualificata, avente l'efficacia prevista dall'art. 2702 del Codice civile²¹.
- **Documento statico non modificabile** - Documento informatico redatto in modo tale che il contenuto risulti non alterabile in fase di accesso e di conservazione nonché immutabile nel tempo; a tal fine il documento non deve contenere macroistruzioni o codice eseguibile, tali da attivare funzionalità che possano modificare gli atti, i fatti o i dati in esso rappresentati.
- **Firma digitale** - Firma elettronica qualificata basata su un sistema di chiavi crittografiche, una pubblica e una privata, correlate tra loro. Tale sistema consente al titolare tramite la chiave privata e al destinatario tramite la chiave pubblica, rispettivamente, di rendere manifesta e di verificare la provenienza e l'integrità di un documento informatico o di un insieme di documenti informatici²².

²⁰ Codice della Amministrazione Digitale - Art. 1 sub p.

²¹ Art. 21 comma 2 - Codice dell'Amministrazione Digitale: "fa piena prova, fino a querela di falso, della provenienza delle dichiarazioni da chi l'ha sottoscritta, se colui contro il quale la scrittura è prodotta ne riconosce la sottoscrizione, ovvero se questa è legalmente considerata come riconosciuta"

²² Codice della Amministrazione Digitale - Art. 1 sub s

- **Firma elettronica** - Insieme dei dati in forma elettronica, allegati oppure connessi tramite associazione logica ad altri dati elettronici, utilizzati come metodo di autenticazione informatica²³.
- **Firma elettronica qualificata** - Firma elettronica ottenuta attraverso una procedura informatica che garantisce la connessione univoca al firmatario e la sua univoca autenticazione informatica, creata con mezzi sui quali il firmatario può conservare un controllo esclusivo e collegata ai dati ai quali si riferisce in modo da consentire di rilevare se i dati stessi siano stati successivamente modificati. La firma elettronica qualificata è basata su un certificato qualificato e realizzata mediante un dispositivo sicuro per la creazione della firma, quale l'apparato strumentale usato per la creazione della firma elettronica²⁴.
- **Incidente di sicurezza** - Ogni evento di natura accidentale o intenzionale che determina il malfunzionamento o l'interruzione, anche parziale, ovvero l'utilizzo improprio delle reti, dei sistemi informativi o dei servizi informatici.
- **Informazione** - Qualunque elaborazione di dati elementari, resa intellegibile per l'uomo, che abbia un valore ed un significato nell'ambito delle Società del Gruppo, indipendentemente dalla sua forma e dagli strumenti utilizzati per il trattamento e la conservazione.
- **Informazione controllata** - Informazione a carattere aziendale o personale la cui circolazione non sottoposta ad un adeguato controllo può comportare un danno all'organizzazione, o al suo patrimonio materiale o immateriale, o agli individui.
- **Informazione controllata a carattere aziendale** - Qualsiasi informazione, generalmente di esclusiva proprietà dell'azienda, riferita direttamente o indirettamente alla natura e alle attività della stessa (dati, notizie, trattati, elaborati, ecc.). Comprendono quelle di esclusiva proprietà del Gruppo FSI, riferite direttamente o indirettamente al business e alle attività dell'organizzazione (dati, notizie, trattati, elaborati, schemi, ecc.); per tali informazioni l'obiettivo è minimizzare i rischi di accesso non autorizzato e di alterazione o distruzione, di tutelare il know-how acquisito, nonché di salvaguardare l'immagine e la posizione di Gruppo rispetto al mercato e agli "stakeholder".
- **Informazione controllata contenente dati personali** - Qualsiasi dato personale (comune, particolare o giudiziario) relativo a persona fisica. Comprende i dati personali affidati al Gruppo e relativi a persone fisiche e per i quali il Gruppo è Titolare del trattamento. Per tali informazioni, l'obiettivo è quello di tutelare la *protezione dei dati personali* degli interessati, anche attraverso l'adempimento dei principi e degli obblighi previsti dal GDPR, dal Codice in materia di protezione dei dati personali e provvedimenti collegati.
- **Informazione pubblica** - Si definisce informazione pubblica qualsiasi informazione (cartacea o digitale) accessibile a tutti (interni ed esterni al Gruppo) senza restrizioni. Tale informazione può, quindi, essere divulgata in funzione di obblighi normativi, contrattuali o per necessità esplicita del Gruppo (ad es. brochure di prodotti e servizi, informazioni pubblicate sul sito internet quali avvisi e annunci di lavoro, rassegne stampa, ecc.).

²³ Codice della Amministrazione Digitale - Art. 1 sub q

²⁴ Codice della Amministrazione Digitale - Art. 1 sub r

- **Informazione verbale** - Si intende, a titolo esplicativo ma non esaustivo, l'informazione acquisita o comunicata nell'ambito della propria attività lavorativa (ad es. riunioni, conferenze, lettura di un documento, ecc.).
- **Integrità** - Grado con cui le informazioni sono aggiornate e sono prive di errori (intenzionali o accidentali). L'Integrità è caratterizzata da due aspetti: correttezza e completezza delle informazioni.
- **Least privilege** - Principio secondo cui un'architettura di sicurezza informatica deve essere progettata in modo che a ogni entità siano concesse le risorse di sistema e le autorizzazioni minime di cui l'entità ha bisogno per svolgere la propria funzione.
- **Marca temporale** - Evidenza informatica che consente di rendere opponibile a terzi un riferimento temporale applicato a un documento.
- **Need to know/need to use** - Principi secondo i quali l'utente ha accesso ai dati in base alla necessità ovvero l'accesso è consentito all'utente soltanto nel caso in cui i dati richiesti siano necessari per poter svolgere il proprio lavoro.
- **Riservatezza** - Grado con cui l'accesso alle informazioni è limitato a un gruppo preventivamente definito e autorizzato.
- **Sensibilità** - Misura qualitativa dell'importanza attribuita alle informazioni e ai sistemi informativi dal rispettivo "proprietario", al fine di assicurare la protezione della riservatezza e dell'integrità.
- **Segregation of duties** - Principio che mira ad ottenere un'adeguata separazione dei compiti e una corretta suddivisione delle funzioni che sono eseguite da parte di una serie di ruoli/responsabilità.
- **Sottoscrizione elettronica** - Apposizione della firma elettronica qualificata (digitale).
- **Tipologia di informazione** - Categoria di informazioni utilizzate all'interno di un'organizzazione o di un settore (es. *protezione dei dati personali*, finanziaria, commerciale, ambientale, ecc.) caratterizzata da specifiche definite oppure derivate da leggi, direttive, regolamenti o altre circostanze.

Nella gestione delle attività afferenti ai processi descritti nel presente documento all'interno del Gruppo, il comportamento del personale coinvolto deve essere coerente con i valori etici perseguiti dal Gruppo FS Italiane e improntato ai principi di imparzialità, liceità, equità, non discriminazione, trasparenza e valorizzazione del merito, anche al fine di garantire parità di trattamento per tutti i soggetti interessati.

CONTRIBUTO ALLA IDENTIFICAZIONE E MITIGAZIONE DEI RISCHI: consentire che i principali rischi siano identificati, valutati, mitigati e monitorati, al fine di supportare il Management nell'assunzione di decisioni consapevoli e allo scopo di minimizzare gli impatti degli stessi sul raggiungimento degli obiettivi cui sono collegati e sulla reputazione della Società.

TRASPARENZA E TUTELA DEGLI STAKEHOLDERS: contribuire a garantire nei confronti degli stakeholders trasparenza nella gestione e nel controllo dei rischi aziendali sui processi descritti nel documento a tutela della reputazione e dell'integrità della Società e degli stessi stakeholders.

ACCOUNTABILITY: chiara definizione di ruoli e responsabilità per i Referenti di Processo che, nell'ambito delle funzioni ricoperte e nel conseguimento dei correlati obiettivi, partecipano attivamente e, per i profili di competenza, assumono le relative responsabilità in relazione alle diverse fasi dei processi descritti nel documento e di individuazione, mitigazione e monitoraggio dei relativi rischi identificati.

SEGREGAZIONE DELLE RESPONSABILITÀ: rispetto del principio della segregazione delle responsabilità in base al quale deve essere garantito che il responsabile dell'attività operativa sia sempre un soggetto distinto da quello che esegue le attività di controllo e di monitoraggio della stessa.

IMPARZIALITÀ E ASSENZA DI CONFLITTI DI INTERESSE: i dipendenti coinvolti nei processi descritti nel documento, devono operare con professionalità e imparzialità evitando ogni situazione dalla quale possa scaturire un conflitto di interesse, ossia una situazione in cui la detenzione, anche indiretta o per conto di terzi, di un interesse secondario interferisce o potrebbe interferire con la capacità di agire nell'interesse primario della Società.

SISTEMA DI DELEGHE E POTERI: definizione formale di deleghe e poteri di firma, in coerenza con le posizioni organizzative e le missioni/responsabilità assegnate, da esercitarsi secondo le modalità ed entro i limiti di valore predefiniti.

TRACCIABILITÀ, ARCHIVIAZIONE E CONSERVAZIONE: i Referenti di Processo devono garantire, per le attività di propria competenza, la tracciabilità degli aspetti sostanziali del percorso decisionale nonché l'archiviazione e la conservazione nel rispetto della normativa applicabile, anche tramite l'utilizzo degli strumenti di collaboration ed informatici messi a disposizione dal Gruppo, della relativa documentazione, assicurando, nel tempo, l'individuazione e la ricostruibilità ex post delle fonti e degli elementi informativi che supportano le attività.

RISERVATEZZA: fermi restando gli obblighi di informazione previsti dalle disposizioni di legge vigenti e la trasparenza delle attività poste in essere, è obbligo dei dipendenti che intervengono nelle fasi dei processi descritti nel documento assicurare la riservatezza richiesta dalle circostanze per ciascuna notizia/informazione appresa in ragione della propria funzione lavorativa, anche in relazione alla particolare sensibilità di alcuni dati trattati.

Riferimenti Normativi Interni

- Codice Etico del Gruppo FS Italiane.
- *Policy* Anti-Corruption del Gruppo FS Italiane.
- *Framenwork di Data Protection*.
- Modello di *Compliance* del Gruppo FS Italiane.
- Modello di *Governance* del Gruppo FS Italiane.
- Modello di Organizzazione e Gestione e Controllo adottato dalle Società del Gruppo ai sensi del D.Lgs n. 231/2001.
- Modello di Gestione *Anti-Corruption* societario.
- Modello di *Governance Security* del Gruppo FS Italiane.
- Modello di Gestione per la Protezione dei Dati Personali del Gruppo FS Italiane.
- *Policy* Utilizzo corretto e sicuro delle Risorse Digitali del Gruppo FS Italiane.

Riferimenti Normativi Esterni

- Decreto Legislativo n. 196, 30 giugno 2003, come modificato dal Decreto Legislativo n. 101, 10 agosto 2018, "Codice in materia di protezione dei dati personali".
- Regolamento (UE) 2016/679 del Parlamento Europeo e del Consiglio del 27 aprile 2016, relativo alla protezione delle persone fisiche con riguardo al trattamento dei dati personali, nonché alla libera circolazione di tali dati (di seguito GDPR).
- Decreto Legislativo n. 58, 24 febbraio 1998, "Testo unico delle disposizioni in materia di intermediazione finanziaria, ai sensi degli articoli 8 e 21 della legge 6 febbraio 1996, n. 52".
- Decreto Legislativo n. 82, 7 marzo 2005, "Codice della Amministrazione Digitale".
- Decreto Legislativo n. 231, 8 giugno 2001, "La Responsabilità d'Impresa".
- Legge n. 48, 18 marzo 2008, "Ratifica ed esecuzione della Convenzione del Consiglio d'Europa sulla criminalità informatica, fatta a Budapest il 23 novembre 2001, e norme di adeguamento dell'ordinamento interno".
- Decreto Legislativo 18 maggio 2018 n. 65, Attuazione della direttiva (UE) 2016/1148 del Parlamento europeo e del Consiglio, del 6 luglio 2016, recante misure per un livello comune elevato di sicurezza delle reti e dei sistemi informativi nell'Unione.
- Decreto-legge 21 settembre 2019 n. 105 (convertito dalla Legge n.133/2019), recante Disposizioni urgenti in materia di Perimetro di Sicurezza Nazionale Cibernetica e successivi Decreti e Provvedimenti attuativi.
- NIST Special Publication 800-60 Volume I Rev. 1, "Guide for Mapping Types of Information and Information Systems to Security Categories".

- NIST Special Publication 800-60 Volume II Rev. 1, “Appendices to Guide for Mapping Types of Information and Information Systems to Security Categories”.
- Framework Nazionale per la Cybersecurity e la Data Protection, Febbraio 2019.
- ISO/IEC 27001:2022, “Information technology - Security techniques - Information security management systems - Requirements”.
- ISO/IEC 27002:2022, “Information technology - Security techniques - Code of practice for information security management”.
- UNI EN ISO 9001:2015 “Sistemi di gestione per la qualità - requisiti”.
- ISO 37301:2021 “Sistema di Gestione della Compliance”.
- ISO 37001:2016 “Anti-Bribery&Corruption management systems”.



VERSIONE/DATA	DOCUMENTO	MOTIVO DELLA REVISIONE
1.0 del 31/10/2024	<i>GR_LG_Classificazione e Protezione delle Informazioni nel Gruppo Ferrovie dello Stato Italiane_n.77</i>	Prima emissione

Il presente documento aggiorna e sostituisce la *CO/G 67/RMCC del 30 giugno 2021 “Clean Desk Policy”*.